EPFL - Computer Science

COM-402 Information Security and Privacy

Lecture 11 — December 1, 2025

Author: Jonathan Dutoit

Professor: Mathias Payer

Privacy

Learning goals

- Privacy is not about hiding, privacy is about preventing harm
- Privacy has many definitions: know your goal and adversary
- Where we need privacy when designing privacy-preserving systems
- A good privacy evaluation requires good threat modeling
- Some example Privacy Enhancing Technologies

Disclaimer: you will not become a privacy engineer today. This is a very light introduction.

Outline

- Why privacy matters
- What is privacy: two angles relevant for privacy engineering
- Building privacy-preserving systems
- Example of PETS and their evaluation
- The quest for anonymization and pitfalls
  - K-anonymity
  - Query auditing
  - Differential privacy

Why Privacy Matters

Privacy is default by law:

Article 12

No one shall be subjected to arbitrary interference with his privacy, family, home or correspondence, nor to attacks upon his honour and reputation. Everyone has the right to the protection of the law against such interference or attacks.

But, in our digital society: many only services collect private data. Thin line between the usefulness of information and data collected.

So what if they know...? I have nothing to hide!

Target(ed) advertising

Target (fancy retailed in the USA - like "Globus") knows what you buy, when you buy it, how often, ...

Target can buy data (from 3rd party brokers) about you:

- **Online**: what websites you visit, how long, in which order, what kinds of topics you search for online, what you like, what you share, ...
- **Offline**: your ethnicity, job history, the magazines you read, if you've ever declared bankruptcy or got divorced, the year you bought your house, where you went to college, the number of cars you own, ...

Target can use this information for

- Sending customers with kids catalogs of toys before Christmas
- Sending customers who buy swimsuits in April coupons for sunscreen in July and died books in December

All of this may bring surprises... "How target figured out a teen girl was pregnant before her father did" in Forbes journal...

Target advertising can also be used to discriminate. Of the 500 simulated users, each, **402** male users received the ad at least once, buy only **60** female users received the same ad at least once.

Facebook / Cambridge Analytica (2016)

Context: CA obtained 50M records from Facebook in 2013 through "survey"app that leaked friends' information as well as from the user answering the survey

CA created a system that can target voters based on psychological profile

Was used to target US voters in 2016 elections and UK voters in Brexit

Consequences

"Brexit vote"and US presidential elections: two leading democracies, find themselves internally polarized.

Attribute-based targeting

Each Facebook user has assigned attributes

- computed by Facebook

- based on Likes, 3rd-party browsing (tracking via "Like" button), etc
- bought form "Partner" companies (Data brokers)

¿ 1200 well-defined attributes

¿ 250k "loosely defined" attributes (from text-processing)

Advertiser select attributes, Facebook relevant ads. Facebook doesn't reveal user identities.

We should use **Privacy plugins!**

Attribute-based targeting: PII-based (Personal Identifying Information)

Advertiser can bulk-upload a database (bough from data brokers, etc.) to Facebook, who tells how many users are present on the system, and allows to target them.

Facebook discovers "similar" people (that are not listed by Data Brokers) based on interests or browsing patterns.

Can be tailored per region, sex, marital status other attributes.

Not really ethical!

2023 - EU Child Sexual Abuse (CSA) regulation debate

Very controversial proposal

REGULATION OF THE EUROPEAN PARLIAMENT AND OF THE COUNCIL laying down rules to prevent and combat child sexual abuse.

"To sway European public opinion, however, the European Commission went even further. X's Transparency Report shows that the European Commission also used 'microtargeting' to ensure that the ads did not appear to people who care about privacy (people interested in Julian Assange) and eurosceptics (people interested in 'nexit', 'brexit' and 'spanexit' or in Victor Orbán, Nigel Farage, or the German political party AfD).[17] For unclear reasons, people interested in Christianity were also excluded. After excluding critical political and religious groups, X's algorithm was set to find people in the remaining population who were indeed interested in the ad message, resulting in an uncritical echo chamber. This microtargeting on political and religious beliefs violates X's advertising policy,[18] the Digital Services Act[19] – which the Commission itself has to oversee – and the General Data Protection Regulation."

The privacy of whom?

Individuals

- protection against profiling and manipulation
- protection against crime / identity theft

Thus privacy is a security property – there is no security without privacy

Companies

- protection of trade secrets, business strategy, internal operations, ...

Governments / military

- protection of national secrets, confidentiality of law enforcement investigations, diplomatic activities, political negotiations

Privacy must be for all

Denying privacy to some is denying privacy to all

INFRASTRUCTURE IS SHARED

Individuals, Industry, and Governments use the same applications!

This can be done either ***directly*** or ***indirectly***. Indirect example: Strava user for militaries in Africa base point out the military base map/schema by running around the military base. Disrupted operation due to secret information leakage.

Security vs. Privacy - Common Misconception

We need tradeoff security for privacy!

More surveillance implies more security which implies a safer world

- Surveillance may be not **effective**: smart adversaries evade surveillance
- Surveillance tools can be **abused**; lack of transparency and safeguards
- Surveillance tools can be **subverted** for crime / terrorism

What is Privacy?

Defining privacy

Privacy is subjective: hard to define

In this lecture: three ways of thinking about privacy depending on what goal are we trying to achieve: they way of reasoning about harm prevention

Different mindsets lead to different technologies - ad different protection!

Privacy as Confidentiality

"The right to be let alone" -Warren Brandeis (1890)

"the individual shall have full protection in person and in property."

- Goal: Minimize data disclosure (which includes distributing trust)
- PETS: encryption, privacy-preserving computation. Obfuscation, decentralization
  - Homomorphic encryption, Secure Multiparty computation, Differential privacy
  - Tor: anonymous communication network

- Mathematical privacy definitions and strong proofs of security

Privacy as Control

"“The claim of individuals, groups, or institutions to determine for themselves when, how, and to what extent information about them is communicated to others” - Westin (1970)

- Goal: Let the user decide how data will be shared and used
- PETS: privacy settings, (automated) privacy policies, logging
  - Secure logging, Sticky policies, ...
- Organizational compliance and fines (GDPR, US Fair information principles)

Privacy as Practice

"The freedom from unreasonable constrains on the construction of one's own identity" - Agre (1999)

- Goal: Improve user agency with respect to private information
- PETS: contextual feedback, privacy nudges

And because privacy is a security property... there is an adversary

Players/Adversaries

Social Context

- Colleagues
- Family and friends
- Strangers

Institutional Adversaries

- Companies
- Advertisers
- Organizations we work for

State-level / Global Adversaries

- Government

Adversaries from social context

Concerns: problems from using technology

- "My boss knows I am looking for another job"

PETs Goal: Do not surprise the user – support decision making

- **Easy defaults**

- **Contextual feedback**
- **Privacy nudges**

Limitations: only protects from other users, service provider is trusted!

- Limited by user's capability to understand policies
- Based on user expectations, what if they are off?

Snapchat have all of your photos!

Many systems can be (stealthily) used for surveillance

Function creep: expansion of a process or system where data collected for one specific purpose is subsequently used for another unintended or unauthorized purpose.

A recurrent function *creep* example: identity systems

Aadhaar - India's "optional" Unique Identity identification number scheme

¿ 1 billion people stored in the database

Goal: *promoted as providing the poor with an identity*

It became:

- *mandatory for opening a bank account*
- *mandatory for benefits system*
- *mandatory for buying a SIM card*
- *required to pay taxes*

EURODAC - fingerprint database for asylum seekers

Goal: store fingerprints from all people who cross the border into a European country without permission – asylum seekers as well as irregular migrants to help immigration and asylum authorities to better control irregular immigration to the EU, detect secondary movements (migrants moving from the country in which they first arrived to seek protection elsewhere) and facilitate their readmission and return to their countries of origin.

It became: database for police and public prosecutors, such as Europol.

More data: in addition to fingerprints, the facial images and alphanumerical data (name, ID or passport number) of asylum seekers and irregular migrants will also be stored.

Institutional adversaries

Concerns: (defined by Legislation) data should not be collected without user consent or processed for illegitimate uses. Data should be secured: correct, integrity, deletion

PETs Goals: Compliance with data protection principles

- Informed consent: valid, freely given, specific, and active consent
- Purpose limitation: data can only be used for the purpose it was collected
- Data minimization: only collect data strictly necessary for service (proportionality)

- Subject access rights: user knows what information is stored/processed and how, user has right to modification and deletion
- Preserving the security of data: auditability and accountability

Limitations

- Assumes: collection and processing by organizations is necessary, organizations are (semi)-trusted and honest, relies on punishments, no mandated technique for the protection of the data
- Focuses on limiting misuse, not collection, easy to circumvent minimization to collect in bulk, auditing require more data! The danger of informed consent: if compliant then it is ok!

Global Adversary

Concern: How to evade / fool a global adversary?

PETs Goals:

- Minimize the need to trust others
- Minimize the amount of revealed information

Limitations:

- Difficult to evolve, combine/compose
- Usability problems both for developers and users
- Lack of incentives:
  Industry: loses the data! No "general-purpose"
  Governments: national security, fraud detection, ...

Building privacy-preserving systems

Privacy engineering process

Step 1: define **"desired uses"** - the purpose of the application

Step 2: identify the **minimal data** need for this purpose

Step 3: build a system that achieves the purpose **minimizing the misuse possibilities** of these minimal data – use Privacy Enhancing Technologies! (full protection may not always be possible)

Step 4: evaluate the system against a **strategic adversary**

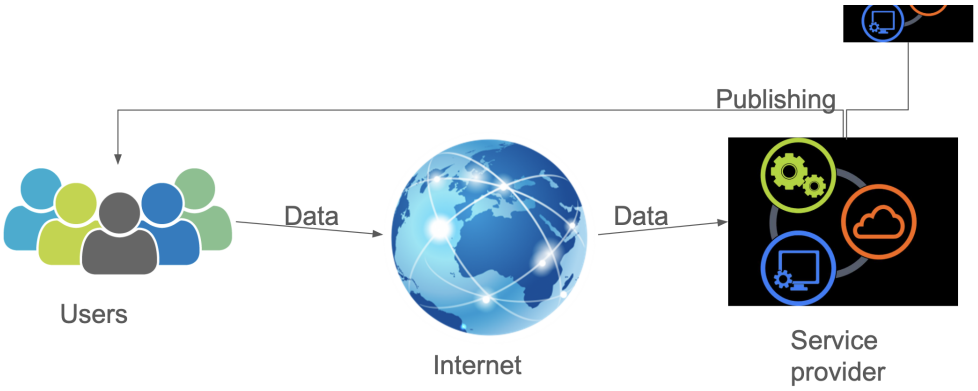
Systematic Privacy Evaluation

- 1) Model the privacy-preserving mechanism as a probabilistic transformation
  - What is the probability that, given an input the privacy mechanism returns a given output?
- Determine what the adversary will see

  - Threat model: who is the adversary? What are her "observations"? What is her prior knowledge?
- 3) "Invert" the mechanism, in the way the adversary would do
  - Always assume the adversary **knows** the mechanism and would try to undo its effect
- 4) Evaluate property after inversion
  - This is the real probability the adversary can compute
- 5) Quantify the probability of success of the adversary
  - Non trivial!

Where can PETs help?

EVERYWHERE: privacy at all layers



An example of evaluation at the application layer

(and how hard it is to get it right)

PETs for Data Anonymization

Scenario: You have a set of data that contains personal data and you would like to anonymize it to:

- not be subject to data protection while processing
- make it public for profit
- make it public for researchers

Goal: Produce a dataset that **preserves the utility** of the original dataset **without leaking information** about individuals. This process is known as **"database sanitization"**

Privacy properties: Anonymity

"Anonymity is the state of being not identifiable within a set of subjects, the anonymity set [...] The anonymity set is the set of all possible subjects who might cause an action"

Decoupling identity and action.

Who is...

- ...the reader of a web page, the person accessing a service
- ..the sender of an email, the write of a text

To achieve anonymity we must *decouple* user identities from user attributes

Let's make users pseudonymous

Medical Data

ID	QID			SA
Name	Zipcode	Age	Sex	Disease
13241	47677	29	F	Ovarian Cancer
542562	47602	22	M	Ovarian Cancer
5377	47678	27	F	Prostate Cancer
73563	47905	43	F	Flu
994356	47909	52	M	Heart Disease
24562	47906	47	F	Heart Disease

Possible existence of other databases (voter registration data)

Medical Data

ID	QID			SA
Name	Zipcode	Age	Sex	Disease
13241	47677	29	F	Ovarian Cancer
542562	47602	22	M	Ovarian Cancer
5377	47678	27	F	Prostate Cancer
73563	47905	43	F	Flu
994356	47909	52	M	Heart Disease
24562	47906	47	F	Heart Disease

Voter registration data

Name	Zipcode	Age	Sex
Alice	47677	29	F
Bob	47983	65	M
Carol	47677	22	F
Dan	47532	23	M
Ellen	46789	43	F

Let's remove identities

Medical Data

QID			SA
Zipcode	Age	Sex	Disease
47677	29	*	Ovarian Cancer
47602	22	*	Ovarian Cancer
47678	27	*	Prostate Cancer
47905	43	*	Flu
47909	52	*	Heart Disease
47906	47	*	Heart Disease

Voter registration data

Name	Zipcode	Age	Sex
Alice	47677	29	F
Bob	47983	65	M
Carol	47677	22	F
Dan	47532	23	M
Ellen	46789	43	F

some attributes are quasi-identifiers

Let's remove some attributes



Caucasian	HIV+	Flu
Asian	HIV-	Flu
Asian	HIV+	Herpes
Caucasian	HIV-	Acne
Caucasian	HIV-	Herpes
Caucasian	HIV-	Acne

Impossible to know what will be a QID

k-anonymity

- **Obfuscate QID** such that anonymity set for a user is at least k
- Each person contained in the database **cannot be distinguished from at least k-1 other individuals** whose information also appears in the released database
- k indicates the degree of anonymity

Key Attribute / Identifier — Quasi-identifier — Sensitive Attribute

name	Age	Zip	Nationality	problem
John	28	13053	Russian	Heart
Zoey	29	13068	American	Heart
Nathan	21	13068	Japanese	Flu
Lucas	23	13053	American	Flu
Sam	50	14853	Indian	Cancer
Max	55	14853	Russian	Heart
Mathias	47	14850	American	Flu
Sarah	59	14850	American	Flu
Chris	31	13053	American	Cancer
Karen	37	13053	Indian	Cancer
Bob	36	13068	Japanese	Cancer
Jane	32	13068	American	Cancer

Equivalence class: group of records that are indistinguishable from QID

k = 4

Age	Zip	Nationality	problem
28	13053	Russian	Heart
29	13068	American	Heart
21	13068	Japanese	Flu
23	13053	American	Flu
50	14853	Indian	Cancer
55	14853	Russian	Heart
47	14850	American	Flu
59	14850	American	Flu
31	13053	American	Cancer
37	13053	Indian	Cancer
36	13068	Japanese	Cancer
32	13068	American	Cancer

Anonymization

Age	Zip	Nationality	problem
4 tuples Zip code = 130** 23 < Age < 29 Average(age) = 25			2 Heart and 2 Flu
4 tuples Zip code = 1485* 47 < Age < 59 Average(age) = 53			1 Cancer 1 Heart and 2 Flu
4 tuples Zip code = 130** 31 < Age < 37 Average(age) = 34			All Cancer Patients

Homogeneity attack: in the third set all patients have cancer. Hence, it one knows Bob, his age and zip code, one can deduce information about the set.

L-Diversity

Goal: preserve privacy by reducing granularity of data, extension of k-anonymity

- An equivalence class has l-diversity if there are at least l **well-presented values for the sensitive attribute**.
- A database has l-diversity if every equivalence class has l-diversity

In the previous table...

3-diverse table: there are (at least) 3 different sensitive conditions in each equivalence class

L-Diversity: Limitations

	ZIP Code	Age	Salary	Disease
1	47677	29	3K	gastric ulcer
2	47602	22	4K	gastritis
3	47678	27	5K	stomach cancer
4	47905	43	6K	gastritis
5	47909	52	11K	flu
6	47906	47	8K	bronchitis
7	47605	30	7K	bronchitis
8	47673	36	9K	pneumonia
9	47607	32	10K	stomach cancer

Original salary/disease table

	ZIP Code	Age	Salary	Disease
1	476**	2*	3K	gastric ulcer
2	476**	2*	4K	gastritis
3	476**	2*	5K	stomach cancer
4	4790*	≥ 40	6K	gastritis
5	4790*	≥ 40	11K	flu
6	4790*	≥ 40	8K	bronchitis
7	476**	3*	7K	bronchitis
8	476**	3*	9K	pneumonia
9	476**	3*	10K	stomach cancer

(*)

3-diverse version of the table

Bob has a low income or is in his 20s, so he has a stomach-related disease.

t-closeness

- An equivalence class has **t-closeness if the distance between the distribution of a sensitive attribute in this class and the distribution of the attribute in the whole table is no more than a threshold t**
- A table has t-closeness if all equivalence classes have t-closeness.
- The distance is usually measured as earth mover's distance (EMD), also known as Wasserstein metric.

Prior Knowledge Attack

Caucasian	787XX	HIV+	Flu
Asian	787XX	HIV-	Flu
Asian	787XX	HIV+	Herpes
Caucasian	787XX	HIV-	Acne
Caucasian	787XX	HIV-	Herpes
Caucasian	787XX	HIV-	Acne

This is k-anonymous, l-diverse and t-close…

…so secure, right?

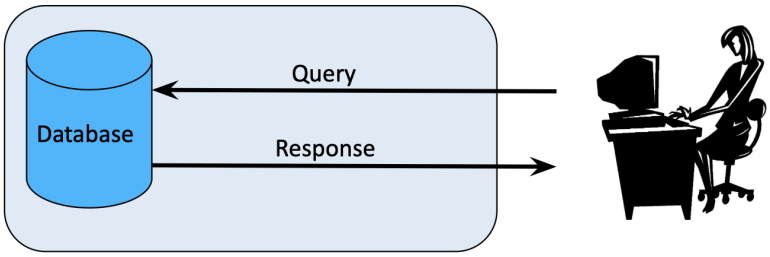
Bob is Caucasian and I head he was admitted to hospital with flu...

The Interactive Scenario

Many times we do not want the data, we want statistics!

Redefined Goal for the interactive case:

Produce an **answer** that preservers the utility of the **statistics** without leaking information about individuals



Query: What is the average salary of female professors at IC@EPFL with Greek nationality?

Is there a privacy problem?

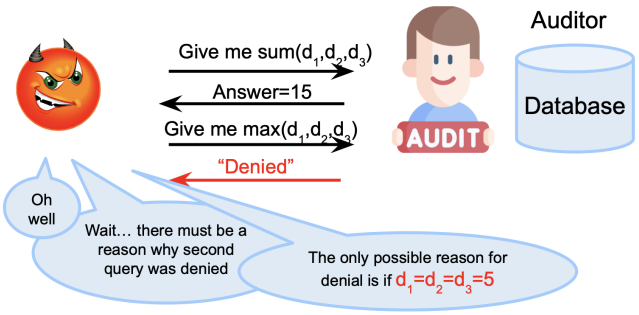
The idea is to audit the queries, if the query will leak, deny!

Either answer truthfully or state that where will be no answer.

Not answering already reveals some information!

When denying fails: learning exact values

Variables d_i are real, privacy breached if adversary learns some d_i



When denying fails: learning internals

$d_i \in [0, 100]$, privacy breached if adversary learns some d_i plus or minus 1

Auditing has problems

- Privacy definition? Privacy of Values? Groups? Exact?
- Algorithm limitations
  - Secure deniability implies using algorithms computationally prohibitive

  - Feasible focus mostly on simple queries
- Collusion? Either high cost or no security
- Utility?
  - Percentage of denials may not be the best measure

Differential Privacy

Remember the Goal for the interactive case

- Produce and **answer** that preserves the utility of statistics without leaking information about individuals
- To have any utility we must allow the leakage of some information, but we can set a bound of the extent of leakage
- **Differential Privacy**: Output is similar whether any single individual's record is included in the database or not.
- **Basic philosophy** : $instead of the real answer to a qurry, add random noise to output, such that by a small change$

- **A new privacy goal**: minimize the increased risk incurred by an individual when joining (or leaving) a given database
- Differential Privacy is a privacy notion **NOT** a meachanism ⇒ We use mechanisms to *achieve* differential privacy (e.g., add random noise)

Informal Definition

Output is similar whether any single individual's record is included in the database or not.

Records's inclusion in the computation does not make it *significantly* worse off.

If there is already some risk of revealing a secret of a record by combining auxiliary information and something learned from DB, then **that risk is still there** but not *significantly* increased by record's participation in the database.

ϵ-Differential Privacy - Format Definition

An algorithm A satisfies ϵ-diffrential privacy if

- For **every pair or neighboring databases** (D, D_{-r}, differing only in row r
- For **every subset S** of **possible output values** taken by A

$$Pr[A(D) \in S] \leq e^{\epsilon} \times Pr[A(D_{-r}) \in S].$$

Principle: The **removal/addition** of a **single record** in the **database should/does not substantially affect the values** of the computed function/statistics.

Properties of Differential Privacy

- **Composability: If algorithms A_1, A_2, ..., A_k** use independent randomness and each A_i satisfies ϵ_i-differential privacy, respectively. Then (A_1, A_2, ..., A_k) is **($\epsilon_1 + \epsilon_2 + ... + \epsilon_k$)-differentially private**
- **Post-processing secure**: If algorithms A is ϵ-differentially private, then for all functions g, g(A) is also ϵ-differentially private (cannot undo privacy with more computations)

How to ensure differentially privacy?

- **Input pertubation**
  - Add noise directly to the database ($\neq$ perturbed database can be published)
    + independent of the algorithm easy to reproduce
    - determing the amount of required noise is difficult
- **Output perturbation**
  - Add noise to the function (statistic) output
    + easier to control privacy better guarantees than input perturbation
    - results cannot be reproduced
- **Algorithm Perturbation**
  - Inherently add noise to the algo
    + algorithm can be optimized with the noise addition
    - difficult to generalize depends on the inputs

Differentialy privacy comes at a cost

- **Impact on accuracy**: we still add noise!
- **Impact is disparate**: we preserve the average signal... but not the outliers
- **Very hard to implement in practice**: sensitivity is not always obvious to compute, independence is not always guaranteed